

Siber Saldırganların Gözünden Kaçmayan 5 Kritik Windows Gerçeği

Giriş

Merhaba! Neredeyse hepimizin her gün kullandığı Windows işletim sistemi, genellikle güvenilir ve tanıdık bir araç olarak görülür. Ancak bu tanıdıklık, bazen tehlikeli bir rahatlığa yol açabilir. Peki, Windows'un kendi içinde barındırdığı, BT yöneticileri için tasarlanmış meşru özelliklerin, aslında siber saldırganlar için ne kadar güçlü birer silaha dönüşebileceğini hiç düşündünüz mü? Bu yazıda, sıradan kullanıcıların genellikle gözden kaçırdığı, ancak siber güvenlik uzmanları için kritik öneme sahip olan, Windows'un en şaşırtıcı ve etkili beş yönünü ele alacağız. Bu gerçekler, en bildiğimiz yazılımların bile nasıl beklenmedik güvenlik riskleri barındırabileceğini gözler önüne seriyor.

1. Gerçek: "Uzak Masaüstü Protokolü" Aslında "Fidye Yazılımı Dağıtım Protokolü" Anlamına Gelebilir

Uzak Masaüstü Protokolü (RDP), BT yöneticilerinin sunucuları ve bilgisayarları uzaktan yönetmesini sağlayan son derece kullanışlı bir özelliktir. Ancak bu kolaylık, doğru yapılandırılmadığında devasa bir güvenlik zafiyetine dönüşür. Bu özelliğin internete açık bırakılması endişe verici derecede yaygındır. Censys Search verilerine göre, şu anda **5 milyondan fazla** RDP özellikli makine internetten erişilebilir durumda. Bu durum o kadar tehlikeli ve yaygın ki, siber güvenlik savunucuları RDP'yi sık sık farklı bir isimle anıyor: **Ransomware Deployment Protocol** (Fidye Yazılımı Dağıtım Protokolü). Zayıf bir parola (Administrator: Summer2025 gibi) ile internete açık bırakılmış bir RDP portu, saldırganlar için açık bir davetiyedir. Saldırgan botnet'leri, Brute Force (Kaba Kuvvet) saldırılarıyla sürekli olarak bu tür sistemleri tarar. Bir analistin Windows Olay Günlüklerine baktığında gördüğü tek bir olay değildir; tek bir IP adresinden gelen binlerce 4625 olay kimlikli (Başarısız Oturum Açma) denemeden oluşan bir fırtınadır. Saatler veya günler süren bu denemelerin ardından, günlüklerde beliren tek bir başarılı 4624 olay kimliği (Başarılı Oturum Açma), sistemin tamamen ele geçirildiği anlamına gelir. Bu durum, yönetim kolaylığı için yapılan basit bir yapılandırmanın nasıl büyük bir siber felakete yol açabileceğinin en net kanıtıdır. *Eğitmen Notu: Bu riski ortadan kaldırmanın en kesin yolu, RDP'yi internete asla doğrudan açmamak ve erişimi her zaman bir VPN (Sanal Özel Ağ) arkasından sağlamaktır.*

2. Gerçek: PowerShell, Saldırganların En Sevdiği "İsviçre Çakısı"dır

Normalde, bir program çalıştırdığınızda, işletim sistemi o iş için tek bir süreç (process) oluşturur. Örneğin, firefox.exe bir web tarayıcısı süreci, notepad.exe ise bir metin düzenleyici süreci başlatır. Ancak powershell.exe bu kuralın bir istisnasıdır. PowerShell, tek bir süreç içinde yüzlerce farklı komut çalıştırabilen güçlü bir komut satırı aracıdır. Bu durum, yalnızca süreç oluşturma olaylarını (Sysmon event ID 1 gibi) izleyen temel güvenlik sistemleri için büyük bir "kör nokta" oluşturur. Saldırganlar, tek bir powershell.exe süreci başlattıktan sonra, yeni süreçler oluşturmadan sistemde keşif yapabilir, veri çalabilir ve hatta internetten ek zararlı yazılımlar indirebilirler. Bu aktiviteler, geleneksel izleme mekanizmaları tarafından fark edilmeyebilir. Bu nedenle, PowerShell aktivitelerini etkin bir şekilde izlemek, PowerShell geçmiş dosyasını kontrol etmek gibi daha derinlemesine yöntemler gerektirir.

3. Gerçek: Windows'un "Yardımsever" Bir Özelliği, En Yaygın Kandırmacıdır

Windows, kullanıcı deneyimini basitleştirmek amacıyla varsayılan olarak bilinen dosya türlerinin uzantılarını gizler. Örneğin, program.exe adında bir dosya, size sadece program olarak gösterilir. Bu "yardımsever" özellik, siber saldırganların en sevdiği kandırmacalardan birinin temelini oluşturur. Saldırganlar, bu özelliği kötüye kullanarak zararlı yazılımlarını masum dosyalar gibi gösterirler. Örneğin, invoice.pdf.exe adında bir dosyayı sisteme soktuklarında, kullanıcı bunu sadece invoice.pdf olarak görür ve bir PDF dosyası olduğunu düşünerek tereddüt etmeden açar. Benzer şekilde, cat.png.com gibi bir dosya, .com uzantısı aslında çalıştırılabilir bir program olmasına rağmen, masum bir resim dosyası gibi görünebilir. Saldırganlar genellikle bu dosyaların ikonlarını da PDF veya resim ikonuyla değiştirerek kandırmacıyı daha inandırıcı hale getirirler. Bu basit ama inanılmaz derecede etkili teknik, kullanıcıları kendi elleriyle kötü amaçlı yazılımları çalıştırmaya ikna eder ve "insan faktörünün" siber güvenlikteki en zayıf halka olduğunun mükemmel bir örneğidir. *Eğitmen Notu: Bu tuzağa düşmemek için, Dosya Gezgini ayarlarından "Bilinen dosya türleri için uzantıları gizle" seçeneğinin işaretini kaldırmak, atılacak en basit ve en etkili adımdır.*

4. Gerçek: USB Saldırıları Sandığınızdan Çok Daha Canlı ve Tehlikeli

Birçok kişi, USB bellekler aracılığıyla yayılan virüslerin artık geçmişte kaldığını ve modasının geçtiğini düşünebilir. Ancak tehdit aktörleri bu fikre kesinlikle katılmıyor. Camaro Dragon veya Raspberry Robin gibi güncel ve sofistike saldırı grupları, bu yöntemi hala aktif olarak kullanıyor. Bu varsayımın yanlış olmasının en önemli nedeni, enfekte bir USB'nin getirdiği tehlikenin boyutudur. Kötü amaçlı bir USB bellek, bir şirketin en güçlü güvenlik duvarlarını (firewall) tamamen atlayarak doğrudan ağın kalbine sızabilir. Hatta internet bağlantısı olmayan, izole edilmiş ("air-gapped") sistemlere bile saldırı başlatabilir. Saldırganlar, kullanıcıları kandırmak için basit ama etkili numaralar kullanır; örneğin, USB içindeki tüm dosyaları gizleyip, klasör gibi görünen Photos.exe adında zararlı bir uygulama oluşturabilirler. Senaryolar ise korkutucu derecede gerçekçidir: "İK departmanından hediye" olarak gelen bir USB bellek veya ortak kullanıma açık bir baskı hizmeti bilgisayarında enfekte olan kendi belleğiniz, farkında olmadan bir saldırının taşıyıcısı olabilir.

5. Gerçek: Saldırganlar Sisteminize Girmek İçin Kendi Araçlarınızı Kullanır

Bir saldırgan bir sisteme sızdıktan sonraki ilk adımları genellikle "Ben kimim?" (whoami) ve "Neredeyim?" (ipconfig) gibi temel soruları yanıtlamaktır. Siber güvenlikte bu süreç "Keşif" (Discovery) adı verilir. Çoğu insan, saldırganların bu aşamada karmaşık ve özel yazılmış araçlar kullandığını düşünür, ancak gerçek tam tersidir. Saldırganlar, bu keşfi yapmak için her Windows makinesinde zaten bulunan yerleşik komut satırı araçlarını (whoami, ipconfig, net user, tasklist vb.) kullanırlar. Bu "araziye uyum sağlama" (Living off the Land) tekniği, adeta bir casusun düşman bölgesine sızdıktan sonra dikkat çekmemek için sadece yerel halkın kullandığı araç ve yöntemleri kullanmasına benzer. Bu durum tespiti inanılmaz derecede zorlaştırır, çünkü kötü amaçlı aktivite, meşru bir sistem yöneticisinin normal faaliyetlerinden ayırt edilemez hale gelir. Tespitteki anahtar, tek bir komutun çalıştırılması değil, bağlamdır. Örneğin, tek başına ipconfig komutu zararsızdır. Ancak mesai saatleri dışında bir kullanıcı hesabının 60 saniye içinde whoami, ipconfig /all, net user ve tasklist komutlarını art arda çalıştırması, tipik bir keşif sekansıdır. Aynı prensip, kalıcılık sağlamak için de geçerlidir. Saldırganlar, sistemde kalıcı erişim elde etmek için yine Windows'un kendi özelliklerini kullanır. Zamanlanmış Görevler (schtasks.exe) veya Başlangıç Anahtarları (reg add ...\\Run)

gibi meşru mekanizmalarla sisteme sızarlar. Özellikle Zamanlanmış Görevler, yapılandırılması ve gizlenmesi kolay olduğu için saldırganlar tarafından kullanılan **en yaygın kalıcılık yöntemidir**. *Eğitmen Notu: Normal kullanıcıların komut satırı araçlarını nadiren kullandığı varsayımı, bu tür aktivitelerin tespitinde en güçlü yardımcınızdır; anomali her zaman bir ipucu taşır.*

Sonuç

Bu yazıda ele aldığımız beş gerçek, siber güvenliğin karmaşık doğasını bir kez daha ortaya koyuyor:

1. Basit bir kolaylık olan **RDP** , devasa bir fidye yazılımı kapısına dönüşebilir.
2. Güçlü bir yönetim aracı olan **PowerShell** , saldırganlar için görünmez bir silah olabilir.
3. Kullanıcı dostu bir özellik olan **dosya uzantılarını gizleme** , en etkili sosyal mühendislik tuzağıdır.
4. Eski moda sanılan **USB saldırıları** , en modern savunmaları bile atlatabilir.
5. Saldırganlar, tespit edilmemek için karmaşık araçlar yerine **sistemin kendi yerleşik komutlarını** kullanır. Bu bilgiler, en tanıdık ve güvendiğimiz yazılımların bile beklenmedik güvenlik riskleri barındırabileceğini gösteriyor. Siber güvenlik, sadece dışarıdan gelen tehditlere karşı değil, aynı zamanda içerideki araçların nasıl kötüye kullanılabileceğini anlamakla da ilgilidir. Bu gerçekleri öğrendikten sonra, her gün kullandığınız Windows sisteminin hangi özelliğine artık daha farklı bir gözle bakacaksınız?